

Contents

Start Here: A Self-Guided Tour of This Security Assessment	1
What am I looking at?	1
A. The 30-second version	1
B. What is GRC, in plain English	1
C. How to use this page	2
D. Tab-by-tab tour	2
Posture (the maturity radar)	2
Risk (the 5 by 5 matrix)	3
Controls (design versus operating)	3
POA&M (the repair plan)	3
Crosswalk (one control, four rulebooks)	4
Third-Party Risk (checking vendors)	4
Deliverables (the paperwork produced)	4
Transferable experience (where the skills come from)	5
Proof (claim-to-evidence map)	5
Demo (poke the live backend)	5
E. Running the live demo yourself	5
F. The deeper study guide	6
G. How to verify nothing is faked	6
H. What this tells you about the candidate	6

Start Here: A Self-Guided Tour of This Security Assessment

What am I looking at?

This website is a security check-up for a company. The company is called Northwind Health Systems, and it is not real. It is a made-up company used for practice, the same way a flight simulator uses a made-up flight to train a pilot. Everything you see was built by Ozirus B. Morency as a portfolio project to show how a real security review is done from start to finish. Think of it as a worked example, not a paid job for a client.

One honest note before you go further. This is entry-level, learning-stage work. It shows the full workflow of a security and compliance review, not years of senior experience. Every number on this page traces back to a file in the project, and nothing is exaggerated. If a claim cannot be backed up by a file, it is not made here.

A. The 30-second version

Here is the whole thing in one paragraph, for a busy reader. This site grades the security program of a fictional healthcare-software company against a well-known government standard, the way a home inspector grades a house against a building code. The company scored 1.57 out of 4.0, which lands it in Tier 2 (Risk Informed): better than chaos, but with clear gaps. The two weakest areas are catching problems and reacting to them. The site then shows the ten biggest risks, tests whether the written safety rules actually work in practice, lays out a repair plan with dates and owners, and proves that one good control can satisfy four different rulebooks at once. There is even a live backend you can poke that recomputes the score in real time. If you want the short story: this is a complete, honest, hands-on security review built by someone learning the field the right way.

B. What is GRC, in plain English

The whole project is an example of GRC. GRC stands for Governance, Risk, and Compliance. Those are three connected jobs that keep an organization safe and trustworthy. Here is each one with an everyday comparison.

Governance is making the rules and deciding who is in charge of what. Think of it as the rulebook and the referees for a sports team. Without governance, everyone plays by their own rules and no one knows who is

responsible when something breaks.

Risk is figuring out what could go wrong, how likely it is, and how bad it would be. Think of it like a weather forecast: it tells you the chance of a storm and how strong the storm might be, so you can decide whether to carry an umbrella or cancel the trip. In security, a risk score is the chance of a bad event multiplied by how much damage it would cause.

Compliance is proving that you actually follow the rules that apply to you. Think of it like a restaurant health inspection. It is not enough to say the kitchen is clean. You have to show the inspector the records, the temperatures, and the cleaning logs. Compliance is the paperwork and the evidence that backs up your promises.

Put together, GRC means: set the rules, measure what could go wrong, and prove you are following the rules. This site walks through all three using one fictional company.

A few more short terms you will meet, defined simply:

NIST is the National Institute of Standards and Technology, a part of the United States government that publishes trusted security guides. CSF is the Cybersecurity Framework, NIST's popular guide for organizing a security program. MFA is Multi-Factor Authentication, which means logging in with more than just a password, such as a password plus a code from your phone. ePHI is electronic Protected Health Information, which is digital medical data that the law says you must guard carefully. POA&M is a Plan of Action and Milestones, which is just a fancy name for a to-do list of fixes with owners and due dates. SOC 2 is a common security report that companies share to prove they protect customer data. ISO 27001 is an international security standard. HIPAA is the United States health-privacy law. TPRM is Third-Party Risk Management, which means checking the safety of the outside vendors you rely on. A BAA is a Business Associate Agreement, the contract a healthcare company signs with a vendor that touches medical data. SIG and CAIQ are two standard vendor questionnaires. SIEM is Security Information and Event Management, a tool that collects and reviews security logs. IAM is Identity and Access Management, the system that controls who can log in and what they can touch. RMF is the Risk Management Framework, another NIST process for managing risk. Each of these is defined again the first time it appears in a section, so you never have to memorize this list.

C. How to use this page

You have two ways to move around. You can click a tab at the top of the screen, or you can simply scroll down from top to bottom. Either way works. Each section is one part of a real assessment, and they are arranged in the order a real review happens: first you measure where you stand, then you find the risks, then you test the controls, then you plan the fixes, and so on.

The page is built to be reachable by keyboard and by touch, not just by mouse. You can press Tab to move between buttons and links, and the interactive charts respond to taps on a phone. If you prefer to be guided, click the button that says Start the guided tour. It walks you through every section in order with short captions, like a tutorial in a video game that points at each part of the screen and explains it.

D. Tab-by-tab tour

This is the heart of the walkthrough. Each part below matches one section of the page, in the order they appear. For each one you get what you see, what to do, the one fact worth remembering, a plain comparison, and a short note on why it matters to you as someone evaluating the candidate.

Posture (the maturity radar)

What you see: a six-sided radar chart and a list of six scores. These six are the Functions of the NIST Cybersecurity Framework: Govern, Identify, Protect, Detect, Respond, and Recover. Each is scored from 1 to 4.

What to do: look at the shape of the radar. The further a point reaches outward, the stronger that area. Short points are weak spots.

The one fact: the overall score is 1.57 out of 4.0, which is Tier 2, called Risk Informed. Protect is the strongest area at 2.00. Detect and Respond are tied for weakest at 1.33 each.

Plain comparison: this is a report card for the whole security program. Just like a school report card shows which subjects are strong and which need help, the radar shows that this company is decent at protecting itself but poor at noticing and reacting to attacks.

Why this matters: a candidate who starts with an honest overall grade, including the bad parts, is showing judgment. The weakest areas, Detect and Respond, are named first and fixed first later. That is how a real assessor thinks.

Risk (the 5 by 5 matrix)

What you see: a grid that is five squares wide and five squares tall, with numbered dots scattered across it. Side to side is likelihood, or how likely a problem is. Up and down is impact, or how much damage it would cause. A card on the side shows the details of the selected risk.

What to do: hover over, tap, or use the keyboard to select a dot. The card updates with that risk's details.

The one fact: there are ten risks. The biggest is R-001, a shared cloud administrator account with no Multi-Factor Authentication (logging in with only a password). Its likelihood is 4 out of 5 and its impact is 5 out of 5, which multiplies to a score of 20, the highest possible, rated Critical. The owner responsible is the CTO, and it maps to the framework control PR.AA-01.

Plain comparison: the matrix is exactly a weather map for danger. The top-right corner is the hurricane zone, where storms are both likely and severe. R-001 sits in that corner.

Why this matters: scoring risk as likelihood times impact is the standard professional method, and putting an owner on each risk shows accountability. A recruiter can see the candidate understands that not all problems are equal, and that the worst ones get a name and a person.

Controls (design versus operating)

What you see: a set of cards, each describing a security control and two test results: design and operating.

What to do: read the two results on each card. Design asks whether the control is set up correctly on paper. Operating asks whether it actually works in real life.

The one fact: control TEST-04 is the incident-response plan. It passes the design test because the written plan exists. It fails the operating test because the plan was never actually practiced.

Plain comparison: this is the difference between owning a fire extinguisher and knowing how to use it. The extinguisher on the wall passes the design test. If no one has ever pulled the pin and sprayed it, it fails the operating test. In an emergency, only the operating test matters.

Why this matters: many people stop at design and call it done. Testing both shows the candidate knows that a rule on paper is worthless if it does not work when it counts. This is one of the most important ideas in auditing.

POA&M (the repair plan)

What you see: a timeline, sometimes called a Gantt chart, where each bar is one fix scheduled over the coming months. POA&M stands for Plan of Action and Milestones, which is a to-do list of fixes with owners and dates.

What to do: read the bars from top to bottom. Notice that the most urgent items are scheduled first.

The one fact: there are ten tracked repair items, each with an owner and a due date. The critical access and detection gaps are scheduled to close first, and the lower-priority polish lands last.

Plain comparison: this is a home-renovation schedule. You fix the leaking roof and the broken furnace before you repaint the guest room. Order matters, and so does putting a name and a deadline on every job.

Why this matters: finding problems is easy. Sequencing the fixes by severity, assigning owners, and setting dates is what turns a complaint into a plan. That is the part employers actually pay for.

Crosswalk (one control, four rulebooks)

What you see: a table with tabs. Each row is a control, and the columns show how that single control maps to four different security frameworks at once.

What to do: click the tabs to filter, and read across one row to see the same control expressed in four different standards.

The one fact: one Multi-Factor Authentication control maps to all four frameworks at the same time. It is CSF PR.AA-01, NIST 800-53 IA-2, ISO 27001 A.5.17, SOC 2 CC6.1, and HIPAA 164.312(a)(2)(i). NIST 800-53 is a detailed United States control catalog, ISO 27001 is an international standard, SOC 2 is a customer-facing security report, and HIPAA is the United States health-privacy law.

Plain comparison: this is like learning that one good habit, brushing your teeth, satisfies your dentist, your doctor, and your own goal of fresh breath all at once. You do the work one time and check several boxes.

Why this matters: this is the core money-saving argument of a unified compliance program. A candidate who can map one control to many frameworks understands how to avoid duplicate work, which is exactly the efficiency a GRC team is hired to deliver.

Third-Party Risk (checking vendors)

What you see: a four-level vendor ranking system, a step-by-step review process, a list of questionnaire topics, and one worked example. This is TPRM, Third-Party Risk Management, which means judging the safety of outside companies you depend on.

What to do: read the four tiers, then look at the worked vendor example to see the system applied.

The one fact: the example vendor, MedStream Analytics, would handle electronic Protected Health Information (digital medical data) with production-like access. That makes it Tier 1, the highest risk. Before any data is allowed to flow, the company must sign a Business Associate Agreement (the required healthcare-data contract) and review the vendor's SOC 2 security report.

Plain comparison: this is a background check before you hand someone the keys to your house. The more sensitive the access, the deeper the check. A house-sitter who only waters the plants gets a light check. One who sleeps in your bedroom and holds your spare key gets a thorough one.

Why this matters: most modern breaches come through a trusted vendor, not the front door. A candidate who screens vendors by how much damage they could do, and who blocks data until the contract is signed, understands where real-world risk actually lives.

Deliverables (the paperwork produced)

What you see: a grid of the actual documents this assessment produced.

What to do: scan the list to see the full set of artifacts behind the charts.

The one fact: the set includes a scope statement, a risk register, a crosswalk, a control test plan, a findings report, a POA&M, a policy, an evidence log, and a vendor-risk program. These are the same document types a real assessment produces.

Plain comparison: the charts on this page are the photos in a real-estate listing, and the deliverables are the full inspection binder behind them. Pretty pictures are nice, but the binder is what a serious buyer reads.

Why this matters: it proves the visuals are not decoration. Each chart is backed by a written document, which is what makes the assessment defensible if someone challenges it.

Transferable experience (where the skills come from)

What you see: a set of cards mapping the owner's prior experience to the skills GRC needs.

What to do: read how each past role connects to a GRC skill.

The one fact: the owner has led more than fifty root-cause analyses and supported federal audits in industrial operations. Those are the same habits of investigation, evidence, and documentation that GRC runs on.

Plain comparison: this is a chef becoming a food-safety inspector. The kitchen skills are not wasted; they transfer. Knowing how a kitchen really runs makes the inspection sharper.

Why this matters: it answers the obvious question, why should I trust someone newer to cybersecurity. The honest answer is that audit discipline, evidence handling, and root-cause thinking came from regulated industrial work and seven years in the National Guard. The field is new, the discipline is not.

Proof (claim-to-evidence map)

What you see: a grid where each résumé claim is tagged with a proof type and tied to the exact file or endpoint that backs it up.

What to do: read a claim, see its proof type, and note that it points to a real file in the public project.

The one fact: every claim is labeled by how it is proven, and each one traces to a repository file or a live endpoint. Nothing is asserted without a source.

Plain comparison: this is showing your work on a math test. The answer alone is not enough; the steps prove you did not guess.

Why this matters: this is the anti-exaggeration section. It lets a recruiter verify each claim instead of trusting it, and it openly labels coursework as coursework and prior operations as prior operations.

Demo (poke the live backend)

What you see: a row of buttons that call a live server, plus a vendor form. The raw answers appear as formatted data below.

What to do: click the buttons and submit the form. See the next section for exact steps.

The one fact: the buttons call real endpoints that compute over the same project data, and one of them recomputes the maturity score to 1.57 on demand. If the server is offline, the page falls back to bundled data and clearly says so.

Plain comparison: this is the difference between a photo of a car and a test drive. A static report is the photo. A live backend that answers your questions is the test drive.

Why this matters: it proves the candidate can build working software, not just write documents. The number on the page is not typed in by hand; it is computed by code from the underlying data.

E. Running the live demo yourself

You do not need any technical skill to try the backend. Follow these numbered steps.

Step one: find the Demo section and click the button labeled API health check. This asks the server if it is awake. You should see a healthy response, and the status indicator turns green. This is like pinging a friend to see if they are online.

Step two: click the button labeled Recalculate maturity to 1.57. This tells the server to add up all the individual scores and compute the overall grade again, from scratch, using the same data the page is built on. Watch it return 1.57. This proves the headline number is calculated, not hand-typed.

Step three: find the vendor form, leave the default name MedStream Analytics in the box, and submit it. The server reads the data and access you selected and returns the vendor's risk tier, which should come back as Tier 1, Critical, with a Business Associate Agreement required.

What this proves: a live backend that answers in real time shows the work is reproducible. Anyone can re-run the math and get the same answer. A static PDF cannot do that. If the server ever sleeps, the page still works from bundled data and tells you it is in fallback mode, so every figure still resolves.

F. The deeper study guide

If you want far more depth than this page, there is a full written guide in the project called the NotebookLM GRC Interview Guide. It is available as a PDF and as a plain text file. It contains the frameworks explained in detail, a question-and-answer bank of likely interview questions with strong answers, and a glossary of terms.

One handy trick: because it is plain text, you can load that guide into a tool like NotebookLM, which can read documents aloud, generate an audio overview, or quiz you on the contents. That makes it easy to study the material on a commute or to prepare for a conversation about the project. The guide is study material that sits behind the live site, for anyone who wants to go from the summary here to the full reasoning.

G. How to verify nothing is faked

You do not have to take any of this on faith. The entire project is public, so you can open the files yourself. Every figure on the page traces to a file in the repository, and the Demo section's backend recomputes the score live so you can check the math. The Proof section maps each claim to its evidence, and the Deliverables section lists the documents that stand behind the charts. If you ever wonder where a number came from, the answer is always a specific file you can open. That openness is the point. An honest assessment invites checking rather than asking for trust.

H. What this tells you about the candidate

Here is the honest close. Ozirus B. Morency is early in a cybersecurity career and is learning the field deliberately, the right way, by doing the full workflow rather than just reading about it. The cybersecurity coursework, including the Google Cybersecurity Professional Certificate finished in June 2026, is foundational and is labeled as exactly that, not as production security operations.

What is not new is the discipline. The real background is industrial operations, including chemical production, support for OSHA and EPA work, more than fifty root-cause analyses, and federal audit support, plus seven years in the United States Army National Guard. That history is genuine audit and documentation experience. This project is the bridge: it converts that proven discipline into modern GRC artifacts, a risk register, control tests, a crosswalk, a POA&M, and a vendor-risk program.

The target is a role in governance, risk, and compliance, moving toward operational-technology and industrial-control-system security, where regulated-industry experience is a real advantage. No claim here is inflated. The work is simulated, the company is fictional, the experience level is entry, and every figure traces to a file. What you should take away is simple: this is someone who can do the whole job honestly, document it clearly, and prove every word of it. That is a rare and hireable combination, especially this early.

Thank you for taking the tour. If you would like to walk through the live page in order, use the button labeled Start the guided tour at the top of the Start Here section, and it will point you through every part in sequence.